

Producto Didáctico: Seguridad de la Información y Marco Legal

Producto Didáctico: Seguridad de la Información y Marco Legal

Objetivo

Este recurso busca enseñar de manera clara y práctica los fundamentos de la seguridad de la información, sus pilares técnicos, amenazas comunes, normativas internacionales y el marco legal colombiano y latinoamericano.

1. Definición

La seguridad de la información es el conjunto de medidas preventivas y reactivas que protegen los datos, garantizando:

- **Confidencialidad:** Solo acceden personas autorizadas.
- **Integridad:** La información no se altera sin permiso.
- **Disponibilidad:** Acceso garantizado cuando se necesita.

Ejemplo práctico: Un banco asegura que sus clientes puedan consultar saldos en línea sin interrupciones, con datos cifrados y verificados.

2. Amenazas y Vulnerabilidades

- **Malware:** Ejemplo WannaCry (2017).
- **Phishing:** Caso Banco de Bangladesh.
- **Fuerza Bruta:** LinkedIn (2012).
- **Inyección SQL:** Heartland Payment (2009).
- **Ingeniería Social:** Kevin Mitnick.
- **Ransomware:** Colonial Pipeline (2021).

Actividad didáctica: Analizar un caso real y discutir cómo se pudo prevenir.

3. Normativas Internacionales

- **ISO/IEC 27001:** Sistema de gestión de seguridad.

- **RGPD/GDPR:** Protección de datos en la UE.
- **NIST CSF:** Marco de ciberseguridad en EE.UU.
- **PCI-DSS:** Seguridad en transacciones con tarjeta.

Ejercicio: Comparar ISO 27001 con NIST CSF y discutir diferencias.

4. Marco Legal en Colombia y Latinoamérica

- **Ley 1273/2009:** Delitos informáticos (hasta 8 años de prisión).
- **Ley 1581/2012:** Protección de datos personales.
- **Ley 1266/2008:** Habeas Data financiero.
- **Decreto 1377/2013:** Reglamenta la Ley 1581.

Caso práctico: Analizar la condena de un ingeniero en Colombia (2020) por acceso abusivo.

5. Responsabilidad del Ingeniero de Software

- **Técnicas:** Cifrado, mínimo privilegio, pentesting, MFA.
- **Legales y Éticas:** Consentimiento, notificación de brechas, respeto a licencias.

Actividad: Crear una lista de buenas prácticas para un proyecto propio.

6. Buenas Prácticas

- Secure by Design.
- OWASP Top 10.
- DevSecOps.
- Control de acceso RBAC.
- Cifrado fuerte (TLS 1.3, AES-256).
- Logs y auditoría con SIEM.

Ejercicio: Diseñar un pipeline CI/CD con controles de seguridad.

7. Conclusiones

- La seguridad es responsabilidad compartida.
- La tríada CIA es el fundamento técnico.
- Estándares internacionales y leyes locales son obligatorios.
- Un ingeniero negligente puede ser sancionado legalmente.

Actividades Didácticas Complementarias

1. **Debate:** ¿Es suficiente la legislación actual para enfrentar ciberataques?
 2. **Mapa Conceptual:** Relacionar amenazas con normativas aplicables.
 3. **Simulación:** Role-play de un ataque de phishing y cómo responder.
-

Frase Inspiradora

"La seguridad no es un producto, sino un proceso." - Bruce Schneier